

Information sheet

Purpose of the Exercise

This exercise is part of an academic research project investigating human decision-making and methodology in web application penetration testing under controlled conditions.

You are asked to perform a Capture-the-Flag (CTF)-style penetration test against a deliberately vulnerable web application. The goal is to observe methodological choices, tool usage, and reasoning, not to assess technical skill or correctness.

Target System Overview

The target is a customized DVWA-based web application, deployed in an isolated environment.

Objective

Your objective is to locate and retrieve the hidden flag from the system. The flag follows a standard CTF format:

FLAG{...}

Once the flag is obtained, you must stop immediately.

Scope and Rules of Engagement

Authorized Scope

You are authorized to test:

- The provided web application only
Only through the supplied network access method

Any activity outside this scope is prohibited.

Permitted Actions

You may use any tools, techniques, and workflows you would normally use during a professional web penetration test, including but not limited to:

- Browsers and developer tools
- Interception proxies
- Scanners and fuzzers
- Command-line tools
- Custom scripts

Prohibited Actions

The following are **not permitted**:

- Use of AI assistance tools (e.g., ChatGPT, Copilot, autonomous agents), unless you are in the “With AI” group.
- Collaboration with other participants
- Testing systems outside the defined target
- Modifying the target application or environment
- Continuing testing after the flag is captured

Environment and Technical Setup

For detailed set up, read the appendix.

Tester Environment

You must use your own machine and tooling, typically:

- Kali Linux or equivalent penetration testing environment
- Virtual machine or bare metal is acceptable

You are responsible for your local setup.

Network Access

Access to the target application is provided via a private overlay network (Tailscale).

High-level process:

1. Install Tailscale on your host or VM
2. Authenticate using a supported identity provider

3. Wait for device approval
4. Access the target via the provided internal IP and port

Once connected, the application should be reachable directly from your tools and browser.

Application Access

You will receive:

- The target URL
- Credentials (if applicable)
- Any required initial configuration instructions

No brute-force attacks against authentication are required or expected unless discovered as part of normal testing.

Documentation Requirements

You must document your work in a written report.

The report should include:

- A chronological description of actions taken
- Tools, commands, payloads, and techniques used
- Your reasoning and decision-making at each stage
- Relevant screenshots or output excerpts
- The final flag

There is no strict format requirement, but clarity and completeness are expected.

Data Collection and Privacy

The following data will be collected:

- Your written report
- The captured flag
- Optional metadata (completion time, general approach structure)

No personal data is collected. Your submission will be anonymized (e.g., *Expert 1*, *Expert 2*).

Ethical and Safety Notes

- The environment is fully isolated
- No real-world systems are involved
- All testing is pre-authorized

Any unexpected behavior, instability, or safety concerns should be reported.

Contact Information

For questions during the exercise or research project:
Julia Vister, master student at UiO, Juliavi@uio.no.

Technical Appendix

Environment Setup and Access Instructions for Expert Testers

This appendix provides detailed technical instructions for setting up access to the penetration testing environment used in the exercise.

It is intended for experienced penetration testers and assumes familiarity with:

- Linux-based penetration testing environments
- Virtual machines and networking
- Common web application testing workflows

No methodological or ethical guidance is included here; this appendix exists solely to ensure reliable and reproducible technical access to the target system.

Tester System Requirements

Operating System

You may use any operating system capable of running standard penetration testing tools. Typical and recommended setups include:

- Kali Linux (bare metal or VM)
- Other Linux distributions commonly used for security testing

macOS or Windows hosts are acceptable if testing tools are run inside a Linux VM.

Virtual Machine Considerations (If Applicable)

If you use a VM:

- The VM must have outbound internet access
 - NAT or bridged networking is acceptable
- No special routing configuration is required beyond standard internet connectivity.

All penetration testing tools must be executed from inside the VM if you choose this approach.

Network Access via Tailscale

Tailscale is used to:

- Restrict access to authorized testers only
- Avoid exposing the target publicly
- Provide stable, flat IP connectivity across heterogeneous systems

From the tester's perspective, the target behaves as if it were on a local private network.

Installing Tailscale

Install Tailscale on the system that will run penetration testing tools (host or VM).

Linux, including Kali:

```
sudo apt update
```

```
sudo apt install tailscale
```

macOS and Windows:

Download the installer from: <https://tailscale.com/download>

Authentication and Device Approval

You will get a link beforehand by the researcher with an invitation link to join the tailscale network used for testing.

1. Start tailscale: `sudo tailscale up`
2. Authenticate using any supported identity provider (Google, GitHub, Microsoft, etc.).
3. Once authenticated, your device will appear as *pending* in the administrator panel.
4. Access is enabled only after *explicit approval* by the researcher.

You will know access is active when Tailscale reports *Connected* and assigns an IP in the `100.x.x.x` range.

Using Tailscale Inside a VM

If using a VM:

- Install Tailscale inside the VM, not only on the host
- Authenticate separately from the VM
- Ensure tools (nmap, browser, proxy, etc.) are executed inside the VM

This ensures that:

- Scans originate from the correct network context
- Reverse shells and callbacks function as expected

Accessing the Target Application

Once connected, the researcher will provide:

- A private IP address (Tailscale IP)
- A port number

Example format: `http://<tailscale-ip>:<port>`

This address should be reachable via:

- Web browser
- Command-line tools
- Interception proxies

Connectivity Verification

Before beginning testing, verify:

```
ping <tailscale-ip>
```

And confirm HTTP access:

```
curl http://<tailscale-ip>:<port>
```

If connectivity fails, confirm:

- Tailscale status is “Connected”
- The correct IP and port are being used
- The test is being run from the Tailscale-connected system

Testing Constraints and Expectations

- Only the provided application may be tested
- No scanning of adjacent hosts on the Tailscale network
- No attempts to identify or exploit the host system beyond the web application context

If issues arise, contact the researcher.

